

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-21 09:00 WIB

Top 5 Highlights

- Malicious npm packages evade install-script defenses at runtime
- Researchers escape OpenAI Codex sandbox to run commands on host
- [+24h Old] Week in review: Cisco patches exploited email gateway 0-day, Revolut breach
- [+24h Old] TigerByte Cyber Emerges From Stealth With \$3 Million in Funding
- [+24h Old] North Korean WaterPlum hackers infected 30,000 devices worldwide

Threat Intelligence (10)

01. Malicious npm packages evade install-script defenses at runtime

An ongoing npm malware campaign involving the 'indexed-btree' package shows how threat actors bypass supply chain defenses by hiding malicious code in a package's normal runtime behavior rather than in installation scripts. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.bleepingcomputer.com/news/security/malicious-npm-packages-evade-install-script-defenses-at-runtime/>

02. [+24h Old] Spear Phishing: How the attack works and how to stop it

Spear Phishing: How the attack works and how to stop it

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources:

<https://www.scworld.com/tech-explainer/spear-phishing-how-the-attack-works-and-how-to-stop-it>

03. [+48h Old] CrowdSec Says TanStack npm Attack Led to Copy of 170 Private GitHub Repositories

An attacker copied about 170 of CrowdSec's private GitHub repositories on May 22 using the account of an employee who had just left, CrowdSec said on September 18. The French security company had kept his GitHub access open. CrowdSec says his laptop was compromised in May's supply chain attack on TanStack, in which malicious versions of TanStack's npm packa...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://thehackernews.com/2026/09/crowdsec-says-tanstack-npm-attack-led.html>

04. [+48h Old] North Korea's fake job interviews infected 30,000 devices

WaterPlum recruiters used bogus coding tests to backdoor jobseekers and raid more than 7,000 crypto wallets

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/09/18/north-koreas-fake-job-interviews-infected-3000-devices/5297461>

05. [+48h Old] New Android malware uses AI to steal bank logins and PINs

RatHat can navigate infected phones while stealing bank logins, authentication codes, and screen-lock PINs.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/news/2026/09/new-android-malware-uses-ai-to-steal-bank-logins-and-pins>

06. [+48h Old] Transparent Tribe Deploys New Rust Backdoor Using Private GitHub Repositories for C2

The Pakistan-aligned threat group tracked as Transparent Tribe (aka APT36 and Earth Karkaddan) has been attributed to a fresh set of cyber attacks targeting government and defense entities in India and Afghanistan. The attacks, per Zscaler ThreatLabz, involve the use of previously undocumented tools called RUSTYSHADE, RUSTYMOVE, PSNATCH, and BASHNATCH. The...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/transparent-tribe-deploys-new-rust.html>

07. [+48h Old] Fake LastPass Authenticator GitHub repos push new Rapuncel infostealer

An ongoing malware campaign uses SEO-optimized GitHub repositories to impersonate well-known software firms to push a previously undocumented information stealer called Rapuncel. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/fake-lastpass-authenticator-github-repos-push-new-rapuncel-infostealer/>

08. [+48h Old] GhostCode attackers abuse device codes to take over Microsoft 365 accounts

Microsoft 365 users are being tricked into handing over access to their accounts by a new phishing kit, GhostCode, that exploits a weakness in a legitimate device authorization flow. Researchers in eSentire's threat response unit identified the campaign in late August 2026. The kit abuses Microsoft's OAuth 2.0 device authorization grant flow, a legitimate m...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.csoonline.com/article/4223898/ghostcode-attackers-abuse-device-codes-to-take-over-microsoft-365-accounts-2.html>

09. [+48h Old] WeaselBiscuit Stealer Spreads via 13 npm Packages to Harvest Chrome Extension Storage

Cybersecurity researchers have discovered a cluster of 13 npm packages that have been found to deliver a previously undocumented JavaScript stealer codenamed WeaselBiscuit. The new malware family, per OpenSourceMalware, exhibits functional overlaps with two malware strains associated with the Democratic People's Republic of Korea's (DPRK) Contagious Interv...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/weaselbiscuit-stealer-spreads-via-13.html>

10. [+48h Old] NightmareStresser DDoS Service Disrupted in International Operation

Active since at least 2022, NightmareStresser was one of the longest-running DDoS-for-hire services in the world. The post NightmareStresser DDoS Service Disrupted in International Operation appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.securityweek.com/nightmarestresser-ddos-service-disrupted-in-international-operation/>

Latest Vulnerabilities (10)

01. Researchers escape OpenAI Codex sandbox to run commands on host

Researchers escaped OpenAI's Codex sandbox two ways, one running commands on a developer's machine from its most locked-down mode. OpenAI has patched both. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/researchers-escape-openai-codex-sandbox-to-run-commands-on-host/>

02. [+24h Old] Week in review: Cisco patches exploited email gateway 0-day, Revolut breach

Here's an overview of some of last week's most interesting news, articles, interviews and videos: What we know about the Revolut data breach so far Someone impersonating a government agency, using an email address on that agency's domain, obtained sensitive customer records from Revolut. The bank confirmed the incident on Saturday, September 12. DeepZero: O...

Why it matters: Publicly discussed 0-days often see rapid weaponization, increasing the risk of opportunistic attacks at scale.

Recommendation: Apply vendor guidance immediately, reduce attack surface, and monitor for IoCs/exploitation telemetry until patches are fully deployed.

Sources: <https://www.helpnetsecurity.com/2026/09/20/week-in-review-cisco-patches-exploited-email-gateway-0-day-revolut-breach/>

03. [+24h Old] TigerByte Cyber Emerges From Stealth With \$3 Million in Funding

The company has secured over \$7 million in contracts with US government agencies, including the US Space Force, the US Navy, and DARPA. The post TigerByte Cyber Emerges From Stealth With \$3 Million in Funding appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.securityweek.com/tigerbyte-cyber-emerges-from-stealth-with-3-million-in-funding/>

04. [+24h Old] North Korean WaterPlum hackers infected 30,000 devices worldwide

A joint law enforcement advisory warns that the North Korean hacking group WaterPlum compromised at least 30,000 devices worldwide from December 2025 through July 2026 and transferred more than \$10.7 million in stolen cryptocurrency to North Korea. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/north-korean-waterplum-hackers-infected-30-000-devices-worldwide/>

05. [+24h Old] Can You Prove a New CVE Is Exploitable Before Attackers Do? Learn How in This Webinar

A new CVE drops. Your scanner finds it. The severity score looks ugly. But that still does not answer the question that matters: Can it actually be exploited in your environment? Mythos-class AI is compressing the time between disclosure and working exploitation, while many security programs still validate risk on weekly or quarterly cycles. The dangerous g...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/can-you-prove-new-cve-is-exploitable.html>

06. [+48h Old] SolarWinds Patches ARM Hard-Coded Key Flaw Enabling Unauthenticated RCE

SolarWinds has released security updates to address a high-severity flaw in Access Rights Manager (ARM) that, if successfully exploited, could lead to an unauthenticated remote code execution vulnerability. The vulnerability, tracked as CVE-2026-28326, is rated 8.8 out of 10.0 on the CVSS scoring system. The issue affects all versions of Access Rights Manag...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/solarwinds-patches-arm-hard-coded-key.html>

07. [+48h Old] Critical Pre-Auth RCE in Orkes Conductor Workflow Platform Exploited in the Wild

A critical vulnerability impacting Orkes Conductor is being actively exploited in the wild, according to Fortinet. The vulnerability in question is CVE-2026-58138 (CVSS v3.1 score: 9.8/CVSS v4 score: 9.3), which relates to a case of unauthenticated remote code execution. "Orkes Conductor 3.21.21 before 3.30.2 contains an unauthenticated remote code executio...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/critical-pre-auth-rce-in-orkes.html>

08. [+48h Old] CISA Flags Three Linux Kernel Vulnerabilities Exploited in the Wild

The U.S. Cybersecurity and Infrastructure Security Agency (CISA) on Friday added three security flaws impacting the Linux kernel to its Known Exploited Vulnerabilities (KEV) catalog, citing evidence of active exploitation. The vulnerabilities are listed below - CVE-2025-39682 (CVSS score: 9.8) - An improper check for unusual or exceptional conditions vulner...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/cisa-flags-three-linux-kernel.html>

09. [+48h Old] HTTP QUERY Method: The Grey Zone Between GET And POST., (Fri, Sep 18th)

In June 2026 the IETF published RFC 10008[1], defining a new HTTP method: "QUERY". The HTTP protocol faced already by changes (HTTP/2, HTTP/3) but it's the first new standard HTTP verb since "PATCH" in 2010!

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://isc.sans.edu/diary/rss/33352>

10. [+48h Old] New CISA-hosted VINCE-NT system revealed for coordinated vulnerability disclosure

CISA says the new system is more streamlined and secure, enabling faster coordination.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/news/new-cisa-hosted-vince-nt-system-revealed-for-coordinated-vulnerability-disclosure>

Data Breach & Cybercrime (10)

01. [+24h Old] ShinyHunters hacks Clop leak site, threatens to extort ransomware gang

The ShinyHunters extortion gang breached the Clop (aka Cl0p) ransomware operation's data leak site, defacing the Tor site and allegedly stealing server data and the private keys for its onion service. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/shinyhunters-hacks-clop-leak-site-threatens-to-extort-ransomware-gang/>

02. [+24h Old] Identity Visibility in 2026: The Foundation of Identity Security

Identity visibility is a starting point for modern identity security, because stolen and misused credentials are among the most frequently reported initial access vectors in breach research, including Verizon's annual Data Breach Investigations Report. This article explains what identity visibility means in IAM, why cloud and multicloud environments complicate...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/09/identity-visibility-in-2026-foundation.html>

03. [+48h Old] FBI: Fake cop and government impersonation scams cost victims \$1.6B

AI, fake uniforms, and mock offices help crooks sell the con

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/cyber-crime/2026/09/18/fbi-fake-cop-and-government-impersonation-scams-cost-victims-16b/5297499>

04. [+48h Old] New Settra Ransomware Variant Deployed in Attacks on Retail and Manufacturing

Huntress researchers highlighted a new ransomware variant, named Settra, and the post-compromise techniques used in two recent attacks

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/settra-ransomware-retail/>

05. [+48h Old] Settra ransomware group uses MeshAgent RMM in recent attacks

The nascent threat actor has claimed 93 victims since June 2026.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.scworld.com/news/settra-ransomware-group-uses-meshagent-rmm-in-recent-attacks>

06. [+48h Old] Manufacturing Accounts for 22% of all Ransomware Victims

Black Kite has found that manufacturing remained the most targeted sector for ransomware attacks, and saw a big jump in incidents in H1 2026

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/manufacturing-22-ransomware-victims/>

07. [+48h Old] AI Agent Breaches Spanish Organization, Modifies Personal Data

AI-driven cyberattacks used to be exotic. Soon, it'll be odd if threat actors aren't using agents to do all of their bidding.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/ai-agent-breaches-spanish-organization-personal-data>

08. [+48h Old] 98% of fraudulent hires have company credentials by the time they're caught

A 90-day period between hiring and onboarding is creating a blind spot in enterprise identity security, according to HYPR's State of HR Identity Fraud Detection report.

"Adversaries no longer need to breach a network when they can pass a remote interview and receive authentic credentials directly from IT," said Bojan Simic, CEO of HYPR.

"Human intuition is...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/18/hypr-hiring-fraud-detection-report/>

09. [+48h Old] Most WordPress pros still lack a breach recovery plan

Melapress, a maker of WordPress security plugins, surveyed 319 WordPress professionals and found that most had dealt with at least one known security incident. The respondents build and run WordPress sites for a living: agency staff, developers, designers, site owners and administrators. Across the whole group, fewer than three in ten have a breach recovery...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/18/wordpress-security-survey-recovery-plan/>

10. [+48h Old] Security spending is growing - except for the typical CISO

Security budgets may be growing on paper, but for a majority of CISOs, the money isn't moving in quite the same direction. The budgets grew by 5% on average in 2026, up from 4% last year. But that average hides a much weaker picture: median budget growth remained at 0%. And while 64% of CISOs asked for an increase this cycle, only 45% received one, meaning...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.csoonline.com/article/4223455/security-spending-is-growing-except-for-the-typical-ciso.html>